عام

نايف خالد السالم

دليل منهجيات الحوكمة والمخاطر والالتزام

كيف أعمل: الخطوات والقواعد والأمثلة المطبقة من دراسة حالة شركة القيروان لنظم المعلومات

رقم الوثيقة	NAS-HBK-001
الإصدار	٠٫٣ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	عام
إشارة المشاركة	أبيض · TLP:WHITE

إعداد نايف السالم

مرجع شخصي وعرض لأسلوب عملي. شركة القيروان لنظم المعلومات وعملاؤها في الأمثلة افتراضيون، أما الأطر والجهات التنظيمية فحقيقية. ويُعتمد النص العربي عند التعارض.

ضبط الوثيقة

الإصدار	التاريخ	المؤلف	التغيير
٠٫١	٧ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى: سبعة فصول مكتوبة وثلاثة هياكل.
٠٫٢	١٠ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الهوية البصرية الجديدة وصفحة الغلاف، وتحسين قابلية القراءة، وإضافة وسم التصنيف «عام» وإشارة المشاركة «أبيض».
٠٫٣	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة.

التصنيف وإشارة المشاركة

الوسم	المستوى	ما يعنيه
التصنيف	عام	لا يترتب على الإفصاح عنها أي ضرر.
إشارة المشاركة (TLP)	أبيض	غير محدود.

مصادر هذا الدليل. الفصول من ١ إلى ٧ مبنية على أعمالي في معسكر الحوكمة والمخاطر والالتزام، ويُذكر مصدر كل فصل في بدايته. والفصول من ٨ إلى ١٠ هياكل أكتبها بنفسي من نقاشاتنا، ولم تُملأ بعد.

الأمثلة. شركة القيروان لنظم المعلومات (QIS) وعملاؤها افتراضيون. أما الأطر والجهات التنظيمية فحقيقية، وتُراجع أرقام الضوابط مقابل نصوصها الرسمية.

كيف يُستخدم هذا الدليل

لكل فصل الأقسام نفسها حتى أصل إلى ما أحتاجه بسرعة:

القسم	ما فيه
متى أستخدمها	الموقف الذي تناسبه المنهجية.
الخطوات	ما أفعله بالترتيب.
القواعد	ما لا أتنازل عنه، والأخطاء التي أتجنبها.
مثال من QIS	المنهجية مطبقة على دراسة الحالة، مع رقم الوثيقة.
المصدر	العمل الذي أُخذت منه المنهجية.

#	الفصل	الحالة
١	تقييم المخاطر وتسجيلها بمصفوفة ٥×٥	مسودة
٢	شجرة الهجوم	مسودة
٣	نمذجة التهديدات بمنهجية STRIDE	مسودة
٤	تصنيف الضوابط الأمنية حسب وظيفتها	مسودة
٥	تصميم مؤشرات الأداء ومؤشرات المخاطر	مسودة
٦	تحليل أثر الأعمال وأهداف التعافي	مسودة
٧	كتابة السياسة والإجراء	مسودة
٨	تقدير الاحتمالية عند غياب البيانات	هيكل، يكتبه نايف
٩	معايير الأثر	هيكل، يكتبه نايف
١٠	الرغبة في المخاطر وصلاحية قبولها	هيكل، يكتبه نايف

١. تقييم المخاطر وتسجيلها بمصفوفة ٥×٥

المصدر: تقييم مخاطر نظام الخدمات المصرفية الإلكترونية لمصرف الإنماء (يونيو ٢٠٢٦م).

متى أستخدمها

عند تقييم مخاطر نظام أو خدمة أو جهة كاملة، وعند بناء سجل المخاطر أو تحديثه.

الخطوات

- **صنّف المخاطر في فئات** قبل تقييمها، لأن التصنيف يكشف ما نسيته. في تقييم الإنماء استخدمت فئتين: النظام وتشغيله والفريق المسؤول عنه، والمستخدمون ووعيهم.
- **أعطِ كل خطر رمزاً ثابتاً** يدل على فئته (A1، B1)، ووصفاً قصيراً يبين ما يحدث ولماذا.
- **اربط كل خطر بالضوابط المقابلة** في الأطر المطبقة (الضوابط الأساسية للأمن السيبراني، وإطار البنك المركزي عند الحاجة)، وتحقق من رقم المكوّن الفرعي من الإصدار الرسمي.
- **قدّر الاحتمالية والأثر** على مقياس من ١ إلى ٥، واضربهما: الخطر = الاحتمالية × الأثر.
- **حدد المستوى** من النطاقات في الجدول أدناه، ثم رتّب المخاطر من الأعلى إلى الأدنى.
- **فصّل أعلى المخاطر**: لكل خطر من ذوي الأولوية القصوى جدول بالأسباب، وخطة المعالجة، والاستراتيجية (تخفيف، أو نقل، أو تجنب، أو قبول).
- **اختم بالخلاصة والتوصيات**: عدد المخاطر، وأعلاها، وأهم الإجراءات.

المستوى	النطاق
كارثي	من ٢٠ إلى ٢٥
مرتفع	من ١٥ إلى ١٩
متوسط	من ٨ إلى ١٤
منخفض	من ٣ إلى ٧
منخفض جداً	من ١ إلى ٢

القواعد

- لا أقيّم خطراً لم أكتبه بصيغة واضحة تبين السبب والحدث والأثر.
- الربط بالضوابط يأتي قبل المعالجة، لأنه يبين أين الفجوة.
- خطة المعالجة تعالج السبب المذكور في الجدول، لا العَرَض.
- قد تجمع الاستراتيجية بين خيارين، كالتخفيف مع النقل الجزئي في هجمات حجب الخدمة.

مثال من QIS

في سجل مخاطر QIS (QIS-RR-001) وُزّعت ٢٠ مخاطرة على فئات، وقُيّم الخطر R-01 (انتشار برمجية فدية عبر أداة الإدارة عن بُعد إلى شبكات العملاء) بأعلى مستوى، وفُصّلت معالجته في خطة الاستجابة للحوادث وخطة استمرارية الأعمال.

قرار: اسم أعلى نطاق هو «كارثي»، كما في تقييم الإنماء الذي راجعه مختص، وتستخدمه جميع وثائق QIS.

٢. شجرة الهجوم

المصدر: تقييم مخاطر مصرف الإنماء، القسم ٧ (شجرة الهجوم للخطر A2، ثغرات واجهات البرمجة).

متى أستخدمها

لخطر واحد عالي المستوى أحتاج إلى فهم طرق وقوعه بالتفصيل، حتى أضع ضابطاً لكل طريق.

الخطوات

- **اكتب هدف المهاجم** في جملة واحدة في رأس الشجرة. مثال الإنماء: الوصول غير المصرح به إلى واجهات البرمجة لسرقة بيانات العملاء أو الاستيلاء على أموالهم.
- **فرّع المسارات الرئيسة** وحدد العلاقة بينها: OR إذا كان نجاح أي مسار يكفي، وAND إذا لزم نجاحها جميعاً.
- **املأ جدول المسارات**: المسار، ونوعه، وجوهر الهجوم، والزاوية التي يستغلها، والضوابط المضادة.
- **ارسم الشجرة** بعد الجدول، فالجدول هو التحليل والرسم توضيح له.

المسار	النوع	جوهر الهجوم	الضوابط
تجاوز المصادقة	سرقة الرمز أو تزويره، وغياب التحقق من الملكية (BOLA)	«أنا لست أنا»	إدارة الهوية والصلاحيات
الحقن والاستغلال	حقن SQL أو NoSQL، وحقن الأوامر، واستغلال واجهة مخفية	الوصول إلى قاعدة البيانات	أمن التطبيقات وجدار حماية التطبيقات
إساءة منطق العمل	تجاوز حدود المعاملة، وغياب تحديد معدل الطلبات	استخدام النظام ضد نفسه	ضوابط بوابة الواجهات والتحقق على جانب الخادم

القواعد

- كل مسار ينتهي بضابط، وإلا فالشجرة ناقصة.
- المسار الذي لا يملك ضابطاً هو أول بند في خطة المعالجة.

مثال من QIS

المرشح الأول لشجرة هجوم في QIS هو بوابة المواطنين لدى العميل (أ)، وهدف المهاجم كشف بيانات المواطنين عبر واجهات البرمجة (السيناريو C-3 في QIS-IRP-001). لم تُرسم الشجرة بعد.

٣. نمذجة التهديدات بمنهجية STRIDE

المصدر: تقييم مخاطر مصرف الإنماء، القسم ٨.

متى أستخدمها

عند تصميم نظام أو مراجعته قبل إطلاقه، وعند إضافة ميزة تعبر حدود ثقة جديدة.

الخطوات

- **ارسم تدفق البيانات** (Data Flow): المستخدم، والحافة، وخادم التطبيق، والبيانات.
- **حدد حدود الثقة** (Trust Boundaries)، لأن التهديدات تظهر عند عبورها. في الإنماء: بين منطقة العميل غير الموثوقة والإنترنت، وبين خادم التطبيق ومنطقة البيانات الداخلية.
- **مرّ على الفئات الست** عند كل حد، واكتب لكل تهديد مكان وقوعه والضابط المضاد.

الفئة	التهديد	أين يحدث (مثال الإنماء)	الضابط المضاد
Spoofing	انتحال الهوية	حد الثقة ١: العميل إلى الحافة	المصادقة متعددة العوامل
Tampering	العبث بالبيانات	النقل وخادم التطبيق	TLS والتحقق من المدخلات
Repudiation	الإنكار	خادم التطبيق	سجلات تدقيق غير قابلة للتعديل
Information Disclosure	كشف المعلومات	حد الثقة ٢: التطبيق إلى البيانات	التشفير وأمن التطبيقات
Denial of Service	حجب الخدمة	حد الثقة ١: الحافة	جدار حماية التطبيقات وتحديد معدل الطلبات وخطة الاستمرارية
Elevation of Privilege	تصعيد الصلاحيات	خادم التطبيق والبيانات	إدارة الصلاحيات الهامة ومبدأ الحد الأدنى من الصلاحيات

القواعد

- كل تهديد لم يُعالج يُسجل خطراً في سجل المخاطر.
- STRIDE تجيب عن «ما الذي قد يحدث»، والمصفوفة في الفصل ١ تجيب عن «ما مدى خطورته».

مثال من QIS

تنص منهجية إدارة المخاطر في QIS (QIS-RMM-001، القسم 0) على تطبيق STRIDE على كل تطبيق تبنيه الشركة أو تستضيفه ويعالج بيانات شخصية أو مصنفة، بدءاً ببوابة المواطنين.

وتضيف سياسة الذكاء الاصطناعي (QIS-POL-002، البند 0,0) تهديدات حقن الأوامر وتسرب البيانات عبر المخرجات.

٤. تصنيف الضوابط الأمنية حسب وظيفتها

المصدر: تمرين «تصنيف الضوابط الأمنية المختلفة»، يوليو ٢٠٢٦م، بالاشتراك مع محمد الشيخ.

متى أستخدمها

عند تحليل الفجوات وعند اختيار المعالجة، للتأكد من أن الخطر لا يعتمد على نوع واحد من الضوابط.

الفئات

الفئة	وظيفتها
وقائي (Preventive)	يمنع الحادثة قبل وقوعها.
كاشف (Detective)	يكتشف الحادثة أثناء وقوعها أو بعده.
رادع (Deterrent)	يثني المهاجم عن المحاولة.
تصحيحي (Corrective)	يصلح الضرر ويعيد الوضع بعد الحادثة.
تعويضي (Compensating)	بديل مؤقت أو جزئي حين يتعذر تطبيق الضابط الأساسي.

تصنيفي للضوابط

الضابط	التصنيف
جدار الحماية، وتجزئة الشبكة، وقوائم التطبيقات المسموحة، وتصفية البريد	وقائي
ضوابط الوصول، والتشفير، ومنع تسرب البيانات، وحماية الأجهزة الطرفية	وقائي
إدارة حزم التحديثات، والتدريب والتوعية الأمنية	وقائي
أنظمة كشف التسلل، ونظام إدارة السجلات والأحداث (SIEM)، ومراقبة سلامة الملفات	كاشف
فحص الثغرات، واختبار الاختراق، والمراجعة اليدوية، والمراقبة المعززة	كاشف
رسائل التحذير، والإشعارات القانونية، والسياسات المعلنة، والإجراءات الأمنية الظاهرة	رادع
خطة الاستجابة للحوادث، والنسخ الاحتياطي والاستعادة، وإدارة الثغرات	تصحيحي
التحليل الجنائي	تصحيحي، وقد يكون كاشفاً

الضابط	التصنيف
التقييد المؤقت	تعويضي
مراقبة نشاط المستخدمين	تعويضي، وكاشف أيضاً
مراقبة السجلات	تعويضي
مصائد المخترقين (Honeypots)	وقائي، وقد يكون كاشفاً

القواعد

- الخطر المرتفع يحتاج إلى ضابط وقائي وضابط كاشف على الأقل، ثم ضابط تصحيحي يحدد كيف نتعافى.
- الضابط التعويضي مؤقت: يُوثق سبب تعذر الأساسي وموعد مراجعته.

نقاط للنقاش قبل الإصدار ١٫٠: بعض المراجع تصنف مصائد المخترقين ومراقبة السجلات ضمن الضوابط الكاشفة، وإدارة الثغرات ضمن الوقائية. أراجع هذه الثلاثة وأقرر هل أُبقي تصنيفي وأكتب مبرره، أم أغيّره.

مثال من QIS

في الخطر R-01 بسجل مخاطر QIS: المصادقة متعددة العوامل على أداة الإدارة عن بُعد ضابط وقائي، ومركز العمليات الأمنية المُدار ضابط كاشف، والنسخ الاحتياطية غير القابلة للتعديل ضابط تصحيحي، وإيقاف الأداة يدوياً حتى اكتمال التجزئة ضابط تعويضي.

٥. تصميم مؤشرات الأداء ومؤشرات المخاطر

المصدر: لوحة مؤشرات الأداء والمخاطر للأمن السيبراني (يناير إلى يونيو ٢٠٢٦م)، عمل جماعي، وسياسة حماية البيانات لشركة SecureTech.

متى أستخدمها

عند إرفاق مؤشرات بكل بند من بنود السياسة، وعند بناء لوحة تقارير للإدارة العليا.

القاعدة الأساسية

	مؤشر الأداء (KPI)	مؤشر المخاطر (KRI)
يقيس	مدى جودة أداء الضابط	مدى اقترابنا من حد الرغبة في المخاطر
المستهدف أو الحد	تفاعلي: يتبع الأداء الفعلي	ثابت: يمثل الرغبة في المخاطر
بعد شهر سيئ	قد يرتفع مستهدف الشهر التالي ثم ينخفض تدريجياً	لا يرتفع الحد أبداً، لأن رفعه يعني قبول خطر أكبر
عند التجاوز	متابعة وتصحيح	تصعيد فوري، وهذا ما صُمم المؤشر لأجله

صيغة المستهدف التفاعلي

المستهدف = الفعلي في الشهر السابق ± خطوة تحسين، مع حد أدنى أو أعلى هو المستهدف النهائي. أمثلة من اللوحة:

المؤشر	الصيغة	الحد
متوسط زمن الاكتشاف	الفعلي السابق ناقص ٠٫٢ ساعة	لا يقل عن ٢٫٥ ساعة
متوسط زمن المعالجة	الفعلي السابق ناقص ٠٫٣٥ ساعة	لا يقل عن ٦٫٥ ساعات
الالتزام بالتحديثات	الفعلي السابق زائد نقطتين	لا يزيد على ٩٨٪

أقسام اللوحة

- الوضع الحالي مقابل المستهدفات النهائية والحدود.
- اتجاهات مؤشرات الأداء مع مستهدفاتها التفاعلية.
- اتجاهات مؤشرات المخاطر مع حدودها الثابتة.
- المسارات غير المنتظمة وأسبابها الجذرية (مثل ارتفاع مارس: أصول جديدة بلا مراقبة، ورفع تجميد التغييرات، ونقص الموظفين، وضبط قواعد الكشف).
- المسافة إلى المستهدف، وهامش الأمان المتبقي قبل الحد.

- أكثر المؤشرات تحسناً.
- جدول البيانات الكامل.
- الإجراءات المطلوبة.

القواعد

- كل بند في السياسة يرافقه جدول مؤشر أداء أو مؤشر مخاطر، أو الاثنان.
- مفتاح ألوان واحد (أخضر وأصفر وأحمر) في كل الوثائق، مع معنى كل لون والإجراء المطلوب.
- لكل مؤشر رمز وتعريف ومستهدف أو حد ودورية قياس.

مثال من QIS

طُبقت القاعدة في لوحة QIS-KPI-001 (بيانات توضيحية من ديسمبر ٢٠٢٦م إلى مايو ٢٠٢٧م)، وفي جداول المؤشرات المرفقة ببنود QIS-POL-001 وQIS-POL-002 وQIS-CHR-001.

٦. تحليل أثر الأعمال وأهداف التعافي

المصدر: خطة استمرارية الأعمال وخطة الاستجابة للحوادث لبنك الحربي (النسخة الرئيسة).

متى أستخدمها

عند إعداد خطة استمرارية الأعمال أو مراجعتها، وعند التفاوض على مستويات الخدمة مع العملاء.

المصطلحات

المصطلح	المعنى
RTO: زمن التعافي المستهدف	أقصى مدة لإعادة الخدمة بعد توقفها.
RPO: نقطة الاستعادة المستهدفة	أقصى قدر من البيانات يمكن فقده، مقاساً بالزمن.
MAO: الحد الأقصى المسموح به للانقطاع	المدة التي يصبح الضرر بعدها غير مقبول.

الخطوات

- **اسرد الخدمات** وحدد لكل منها العميل والأثر عند انقطاعها.
- **حدد الحد الأقصى المسموح به للانقطاع** من الأثر، ثم زمن التعافي المستهدف أقل منه بهامش واضح، ونقطة الاستعادة من مدى تغير البيانات.
- **رتّب الأولويات** بحسب الأهداف: الأقصر زمناً أولاً.
- **أعدّ مصفوفة استمرارية** لكل خدمة ذات أولوية.

في خطة بنك الحربي كان زمن التعافي المستهدف نصف الحد الأقصى أو أقل في كل السيناريوهات (مثل ساعة مقابل ساعتين، و٣٠ دقيقة مقابل ساعة، و٤ ساعات مقابل ٨ ساعات). وطُبقت القاعدة نفسها في QIS.

حقول مصفوفة الاستمرارية

الحقل	ما يُكتب فيه
الوصف	ما الخدمة ولمن.
التبعيات	الأنظمة والموردون والأشخاص الذين تعتمد عليهم.
السيناريوهات	ما الذي قد يوقفها.
مستوى الخطر	من سجل المخاطر، مع أرقام المخاطر.
إجراءات استباقية	ما نفعله الآن لتقليل الأثر.
أثناء الحادثة: الاستمرارية	كيف تستمر الخدمة بالحد الأدنى.

الحقل	ما يُكتب فيه
أثناء الحادثة: التعافي	ترتيب الاستعادة.
بعد الحادثة	التحقق والعودة والدروس المستفادة.
الأهداف والمسؤولون	RTO وRPO وMAO، والمالك، والمكلف بالإبلاغ.

مثال من QIS

في QIS-BCP-001 حُددت لبوابة المواطنين: حد أقصى ٨ ساعات، وزمن تعافٍ ٤ ساعات، ونقطة استعادة ١٥ دقيقة، والأولوية ١. وتبقى هذه القيم مقترحة حتى تُطابق مع عقد العميل (أ).

٧. كتابة السياسة والإجراء

المصدر: سياسة حماية البيانات لشركة SecureTech، وسياسة وإجراء استخدام الذكاء الاصطناعي.

هيكل السياسة

#	القسم	ملاحظة
١	ضبط الوثيقة	المالك والمراجع والمعتمد، وسجل الإصدارات، ودورة المراجعة.
٢	مفتاح ألوان المؤشرات	مرة واحدة في بداية الوثيقة.
٣	التعريفات	كل مصطلح يُستخدم بمعنى محدد.
٤	الغرض والنطاق	ما الذي تحميه السياسة، ومن تنطبق عليه، وما الخارج عن نطاقها.
٥	المبادئ	عند الحاجة، كما في سياسة الذكاء الاصطناعي.
٦	بنود السياسة	بنود مرقمة، يتبع كلاً منها جدول مؤشرات.
٧	الأدوار والمسؤوليات	مصفوفة RACI.
٨	الإجراء	جدول خطوات: المسؤول والمخرج والمدة.
٩	عواقب عدم الالتزام	
١٠	المراجعة والمراجع والتواصل	

القواعد

- البند يُكتب بصيغة إلزامية قابلة للقياس، وإلا فلا يمكن تدقيقه.
- السياسة تقول «ماذا»، والإجراء يقول «كيف»، ويمكن جمعهما في وثيقة واحدة بقسمين منفصلين.
- مصفوفة RACI: مساءَل واحد فقط لكل نشاط.

مثال من QIS

QIS-POL-001 سياسة حماية البيانات، وQIS-POL-002 سياسة وإجراء استخدام الذكاء الاصطناعي.

٨. تقدير الاحتمالية عند غياب البيانات

هيكل يكتبه نايف. مبني على نقاشنا حول الخطر R-01. نقطة البداية هي ترتيب الأدلة الذي وضعته: هل وقع في جهة العمل من قبل؟ هل توجد أرقام في القطاع؟ إن لم يوجد هذا ولا ذاك، نضع رقماً بتبرير جيد.

أسئلة أجيب عنها في هذا الفصل

- ما تعريفي للاحتمالية؟ (اتفقنا أنها مقياس للفرصة، سواء عُبّر عنها باحتمال أو تكرار)
- ما ترتيب مصادر الأدلة، ولماذا بهذا الترتيب؟
- عند غياب البيانات، ما العوامل التي أقيّمها، وكيف أجمعها في رقم واحد؟
- لماذا اخترت ٣ للخطر R-01 مع خطورته، ومتى أعيد تقديره؟
- كيف أوثق التبرير حتى يراجعه غيري؟

نصي

(يُكتب هنا)

٩. معايير الأثر

هيكل يكتبه نايف. معايير الأثر في QIS-RMM-001 مسودة أضفتها لتكتمل الوثيقة، وتحتاج إلى مراجعتك وصياغتك.

أسئلة أجيب عنها في هذا الفصل

- ما أبعاد الأثر التي أقيس بها (مالي، تشغيلي، تنظيمي، بيانات، سمعة)؟
- كيف أحدد حدود كل مستوى، خاصة المبالغ المالية؟
- لماذا يُعتمد أعلى بعد لا متوسط الأبعاد؟

نصي

(يُكتب هنا)

١٠. الرغبة في المخاطر وصلاحية قبولها

هيكل يكتبه نايف. الرغبة في المخاطر وجدول صلاحيات القبول في QIS-RMM-001 مسودة أضفتها،

وتحتاج إلى مراجعتك وصياغتك.

أسئلة أجيب عنها في هذا الفصل

- كيف أعبّر عن الرغبة في المخاطر لجهة تخدم عملاء حكوميين؟
- من يقبل كل مستوى من المخاطر، ولأي مدة؟
- كيف ترتبط حدود مؤشرات المخاطر الثابتة بالرغبة في المخاطر؟ (انظر الفصل ٥)

نصي

(يُكتب هنا)